00199



Sri Lanka Institute of Information Technology

B.Sc. Honours Degree in Information Technology

Specialized in Cyber Security

Final Examination
Year 3, Semester 1&2 (2023)

IE3032 – Network Security

Duration: 2 Hours

June 2023

Instructions to Candidates:

- This paper has 4 Questions.
- Answer all questions in the booklet given.
- The total marks for the paper is 100.
- This paper contains 8 pages, including the cover page.
- One handwritten A4 paper can be brought into exam hall

Question 01 Layer 2 Security [25 marks]

a. You are the network administrator for a medium-sized company. The company has sensitive data that needs to be protected from unauthorized access. The network infrastructure includes Cisco Catalyst switches that connect various devices, such as computers, servers, and printers. The company wants to ensure that only authorized devices are allowed to connect to the network, prevent CAM table attacks, restrict the number of allowed MAC addresses on each switch port, set a maximum limit for the number of allowed MAC addresses, and configure violation actions.

i. Analyze the scenario and suggest which security measure you think is most suitable to enhance the security of the switches.

(2 marks)

ii. The company had the following requirements to be implemented in the switch. Please mention the appropriate commands that must be used.

(8 marks)

1. Enable port security on interface Fast Ethernet ports 0/1 and 0/2

2. Set the maximum allowed MAC addresses to 5 on the interface.

3. Configure the violation action to be "shutdown" on the interface.

4. Disable all the remaining unused ports. (Interface Range f0/3 - 24, g0/1 – 2)

b. Now the company has a large number of devices that obtain IP addresses from the DHCP server. The network infrastructure includes Cisco Catalyst switches that are connected to multiple VLANs, and the DHCP server is in a trusted VLAN. The company wants to prevent unauthorized devices from acting as DHCP servers and distributing rogue IP addresses to other devices on the network.

i. Analyze the scenario and suggest which security measure you think is most suitable to enhance the security of the switches.

(2 marks)

ii. The company had the following requirements to be implemented in the switch. Please mention the appropriate commands that has to be used.

(9 marks)

1. Enable DHCP snooping globally.

2. Configure the trusted VLANs where the DHCP server is located. (VLAN 1)

3. Enable DHCP snooping on interface Fa0/4

4. Rate limit on the Fa0/4 interface for 20

iii. What is the best methods that can be used to thwart VLAN hopping attacks?

(4 marks)

Question 02 ACL and Firewalls [25 marks]

a. A company is planning to deploy a new web application that will be accessible from the Internet. The web application will allow customers to place orders, view product details, and submit support tickets. The company's internal network contains servers that handle inventory management, shipping, and other backend operations. The company is more concerned with securing the internal network and wants to have more control over traffic between different parts of the network.

i. As a network administrator, analyze the situation and recommend the most suitable firewall between using a zone-based firewall or a DMZ?

(2 marks)

ii. You are instructed to configure a Zone based policy firewall on Router 3. Please mention the appropriate commands that has to be used.

(6 marks)

1. Create a zone named IN-ZONE

2. Create a zone named OUT-ZONE

3. Assign interfaces G0/1 to IN-ZONE security zone and S0/0/1 to OUT-ZONE security zone.

b. The senior network administrator has asked you to create a standard named ACL to prevent access to a file server. The file server contains the data base for the web applications. Only the Web Manager workstation PC1 and the Web Server need to access the File Server. All other traffic to the File Server should be denied. You are required to fulfill the below requirement on **R1** and **R2**. Please mention the appropriate commands that has to be used.

(12 marks)

i. Configure a named ACL on R1 called "File_Server_Restrictions"

ii. Permit the hosts 192.168.20.4 and 192.168.100.100

iii. Deny any other traffic.

iv. Apply the named ACL outbound on the Fast Ethernet 0/1 interface.

v. Create an numbered ACL using the number **1** on **R1** with a statement that denies access to the 192.168.20.0/24 network from the 192.168.11.0/24 network

c. Explain the concept of a Next Generation Firewall and compare it to Traditional Firewalls.

(5 Marks)

Question 03 VPN and AAA [25 marks]

a. You are the network administrator for a large company that handles sensitive financial data. Your company has recently expanded and now has remote employees working from different locations around the world. In addition, the company's partners and clients need to access the company's network to collaborate on projects and share information. Your company is concerned about the security of its network and wants to implement measures to control access and protect its data. As a network administrator, you have decided to implement both site-to-site VPN and remote access VPN for a company's network. Justify your selection by providing a detailed analysis of the company's requirements and how each type of VPN meets those requirements.

(6 Marks)

b. A medium-sized company has multiple offices across the country, and each office has its own network devices, such as switches, routers, and firewalls. The company wants to implement a centralized authentication and authorization system for all network devices to enhance security and simplify management. The company has two main requirements: first, network administrators should be able to manage all network devices from a central location using a single set of credentials; second, the company wants to keep track of who is accessing the network and what actions they are taking, so it can monitor and audit network activity. As the network administrator, you have decided to implement TACACS+ and RADIUS as the authentication and authorization protocols for the network devices.

Device	Interface	IP Address	Subnet Mask	Default Gateway	Switch Port
R1	G0/1	192.168.1.1	255.255.255.0	N/A	S1 F0/1
	S0/0/0 (DCE)	10.1.1.2	255.255.255.252	N/A	N/A
R2	G0/0	192.168.2.1	255.255.255.0	N/A	S2 F0/2
	S0/0/0	10.1.1.1	255.255.255.252	N/A	N/A
	S0/0/1 (DCE)	10.2.2.1	255.255.255.252	N/A	N/A
R3	G0/1	192.168.3.1	255.255.255.0	N/A	S3 F0/5
	S0/0/1	10.2.2.2	255.255.255.252	N/A	N/A
TACACS+ Server	NIC	192.168.2.2	255.255.255.0	192.168.2.1	S2 F0/6
RADIUS Server	NIC	192.168.3.2	255.255.255.0	192.168.3.1	S3 F0/1

PC-A	NIC	192.168.1.3	255.255.255.0	192.168.1.1	S1 F0/2
PC-B	NIC	192.168.2.3	255.255.255.0	192.168.2.1	S2 F0/1
PC-C	NIC	192.168.3.3	255.255.255.0	192.168.3.1	S3 F0/18

i. Refer the above table and you are required to fulfill the below requirements. Please mention the appropriate commands that has to be used.

(9 Marks)

1. For backup purposes, configure a local username of Admin2 and a secret password of admin2pa55 on R2.

2. Configure the AAA TACACS server IP address and secret key (tacacspa55) on R2.

3. Configure AAA login authentication for console access on R2.

4. Configure the AAA RADIUS server IP address and secret key (radiuspa55) on R3.

5. Configure the line console to use the defined AAA authentication method.

ii. The upper management has asked you to select two options: implementing server-based AAA authentication or local AAA authentication. analyze the situation and recommend the most suitable AAA authentication method between server-based AAA and local AAA authentication. What are the benefits and drawbacks of each method, and how will your recommendation improve network security?

(5 Marks)

c. A large e-commerce company recently experienced a security breach, which resulted in the theft of customer data such as names, email addresses, and credit card information. The company's security team suspects that the attackers used a replay attack to gain access to the company's network.
(5 Marks)

i. What is a Replay attack and how does it work?

ii. As the network administrator, what steps would you take to prevent replay attacks from occurring in the future?

Question 04 Network Attacks and Defense [25 marks]

a. Imagine you have been hired as a senior security engineer at a company which has been struggling with its information security posture. Due to new regulatory requirements the senior management has decided that an overall audit and revision of its cybersecurity capability and requirements is needed. Below are the details of the findings after 3 successful attacks on the company's network. Analyze the below scenarios and identify the attack that has taken place and identify and justify what is the best form of mitigation that can be used to stop such attacks in the future.

(9 Marks)

i. After employees complained of connectivity issues further investigation showed that switch MAC address tables were filled with MAC addresses not connected to the network.

ii. After a few days in which the company web server crashed frequently the network logs were examined. It was found that that each time the webserver crashed after a fragmented ICMP echo request was received and processed by the server. It was also found that due to budgetary issues the OS used on the server was windows XP.

iii. After complaints about the website being unresponsive it was found that the server was using many resources to respond with ICMP messages to UDP packets meant for non-active ports. Further investigation revealed that the UDP datagrams originated from different IP addresses.

b. The company has now decided to improve its security posture by implementing an overarching security policy and developing DR and BCP plans. Based on the current threats faced by companies, identify 2 key policy documents that should be developed and what areas each should cover. For each document identify and write 2 key rules you will include.

(8 Marks)

c. The company is now in the process of updating its security infrastructure. Identify and justify the best option for the below scenarios.

(8 Marks)

i. The company has been using a dedicated leased line to connect its branches and the main HQ. Due to network expansion the currently available leased lines are not sufficient to handle the required traffic and a new one is extremely costly. The ISP has public fiber lines which are sufficient at much cheaper rates but security over the public network is not provided. Also, some workers are still working with work from home contracts, and they also require secure access to the internal networks. What solution do you recommend being used for this situation.

ii. The HQ is now thinking of bringing its previously outsourced website and server in-house. In addition, due to company expansion the number of internal sub-networks has significantly grown, and the security requirements of each network are different. Therefore, it has been decided that there need to be rules for what traffic can pass between even the external sub-networks. What topology and type of firewall would you recommend being used?

***